

Digital Certificates & PKI

The Problem Certificates Solve

How does your browser know it's REALLY talking to example.com and not the attacker's server? The answer is **Public Key Infrastructure (PKI)** – a system of trust.

X.509 Certificates

A TLS certificate is a data structure containing:

Subject – who it's issued to (CN/domain)

Issuer – who signed it (the CA)

Public key – the site's public key

Validity dates – not before / not after

Signature – CA's signature over the rest

Extensions – SANs (alternate names), usage constraints

The Chain of Trust

```
Root CA (trusted, built into your OS/browser)
└─ signs → Intermediate CA
    └─ signs → example.com certificate (leaf)
```

Your browser stores the **root CA** certificates (from OS or browser vendor). To verify example.com, it walks the chain: leaf → intermediate → root. If any signature fails to verify, or a cert is expired/revoked, the browser warns.

PKI Operations (What Real Analysts Do)

Enroll – request a cert (CSR) from a CA for a domain

Validate – CA proves you own the domain (DV/OV/EV levels)

Issue – CA signs and publishes

Renew – before expiry

Revoke – CA publishes the cert in a CRL/OCSP

Audit – check all certs on your domains, expiry, validity

Trust Anchors & the CA System

Root CAs are the trust anchors – preinstalled

Compromised CA = false certs for anyone (the **DigiNotar 2011** case: fake Google certs)

Certificate Transparency (CT) logs every cert → detection of rogue certs

Common PKI Misconfigurations (Blue Team)

Expired certs → outages (available to see errors)

Self-signed certs in production → users trained to ignore warnings (bad!)

Wildcard certs shared → blast radius if key leaks

Weak key ⚡ RSA-1024/ SHA-1 signatures legacy

Certificate Validation – The Attack Angle

MITM requires the victim to accept a fake cert (users clicking through warnings)

Phishing with free HTTPS – DV certs are free, so "HTTPS padlock" ≠ "secure" – always check the DOMAIN

Phishkit "sharks" named after legit domains but with '.xyz' – cert checks save you

Padlock ≠ safe. The padlock only guarantees channel encryption, not the identity of who you're talking to. Always verify the domain.

[← Symmetric & Asymmetric Algor...](#)

[TLS in Practice: Handshakes & ...](#)